

Threat Hunting Report: APT29 (Cozy Bear)

Prepared by: Solomon Mwaura

Date: February 19, 2026

1. Introduction

Purpose: Provide an overview of the lab, the scenario being analyzed, and the objectives of the exercise.

Scenario Summary: APT29 (Cozy Bear) launched a targeted cyber-espionage campaign against DataSecure Inc. to exfiltrate sensitive financial data. The attackers gained initial access via a spearphishing link, utilized fileless malware and zero-day exploits to establish a foothold, and leveraged native Windows tools (RDP, WMI, PowerShell) to move laterally and evade detection before exfiltrating encrypted data over HTTPS.

Lab Objective: This lab focuses on analyzing an attack scenario and mapping the observed behaviors to MITRE ATT&CK techniques to better understand adversary tactics and develop mitigation strategies.

2. Hypothesis

Purpose: Define a clear hypothesis based on the provided attack scenario.

Hypothesis: Based on the scenario details, it is hypothesized that APT29's primary goal was the stealthy exfiltration of sensitive financial data (Espionage). To achieve this, the adversary likely relied heavily on "Living off the Land" (LotL) techniques such as PowerShell, RDP, and WMI—combined with custom malware and zero-day/known exploits—to minimize their footprint, bypass endpoint defenses, and maintain persistent, highly privileged access.

3. Observed Activities and TTPs

Tactic	Technique Name	Technique ID	Description / Observed Activity
Initial Access	Phishing: Spearphishing Link	T1566.002	Attackers sent a targeted email containing a link to a malicious website. An employee clicked the link, leading to the execution of a fileless malware stager.
Execution	Command and Scripting Interpreter: PowerShell	T1059.001	The malware stager utilized PowerShell to download and execute additional payloads directly into memory, bypassing disk-based detection.

Tactic	Technique Name	Technique ID	Description / Observed Activity
Privilege Escalation	Exploitation for Privilege Escalation	T1068	Adversaries leveraged a zero-day exploit in the Windows kernel to elevate their privileges from a standard user to SYSTEM level.
Lateral Movement	Remote Services: RDP / WMI	T1021.001 / T1047	The attackers moved across the network using the Remote Desktop Protocol (RDP) and Windows Management Instrumentation (WMI), utilizing compromised administrative credentials.
Defense Evasion	Hijack Execution Flow: DLL Side-Loading	T1574.002	Adversaries used DLL side-loading to execute a malicious library by placing it in the directory of a legitimate, trusted application.
Defense Evasion	Indicator Removal: Clear Windows Event Logs	T1070.001	To hide their activity, the attackers cleared the Windows security and system event logs after completing their lateral movement tasks.
Exfiltration	Exfiltration Over C2 Channel	T1041	Encrypted financial data was exfiltrated to the attackers' command and control (C2) server over HTTPS, blending in with legitimate web traffic.

4. Threat Hunting Queries (KQL)

Purpose: Develop queries to detect the observed techniques in a hypothetical SIEM/EDR environment.

1. Detecting Malicious PowerShell Execution (T1059.001)

```
DeviceProcessEvents
| where ProcessCommandLine has_any ("-ExecutionPolicy Bypass", "-WindowStyle Hidden", "IEX", "Invoke-Expression")
| where InitiatingProcessFileName in~ ("powershell.exe", "pwsh.exe")
| project Timestamp, DeviceName, FileName, ProcessCommandLine, InitiatingProcessFileName
```

2. Detecting Unauthorized RDP Activity (T1021.001)

```
DeviceNetworkEvents
| where RemotePort == 3389
| where InitiatingProcessFileName !in~ ("mstsc.exe", "RdcMan.exe") // Filter out common tools
| project Timestamp, DeviceName, LocalIP, RemoteIP, InitiatingProcessFileName
```

3. Detecting Windows Event Log Clearing (T1070.001)

```
DeviceProcessEvents
| where FileName =~ "wevtutil.exe"
| where ProcessCommandLine has_any (" cl ", "clear-log")
| project Timestamp, DeviceName, AccountName, ProcessCommandLine
```

5. Mitigation and Recommendations

Mapped Technique	Mitigation Strategy
Phishing (T1566.002)	Implement robust email filtering/sandboxing solutions. Conduct routine phishing awareness training. Use multi-factor authentication (MFA) to limit the impact of compromised credentials.
PowerShell (T1059.001)	Enable PowerShell Script Block Logging to monitor execution. Enforce strict execution policies and use Just Enough Administration (JEA) to limit PowerShell capabilities for standard users.
Exploitation (T1068)	Implement a robust, prioritized patch management system to rapidly deploy updates for critical OS vulnerabilities. Use Endpoint Detection and Response (EDR) to detect exploitation behaviors.
RDP / WMI (T1021.001 / T1047)	Disable RDP and WMI if they are not required. If required, restrict access via network segmentation, enforce MFA, and limit usage to monitored jump servers and administrative accounts.
DLL Side-Loading (T1574.002)	Audit and restrict file and directory permissions to prevent standard users from writing to locations where legitimate services search for DLLs. Ensure software is compiled with safe DLL search modes enabled.
Indicator Removal (T1070.001)	Forward all crucial system and security event logs to an external, centralized SIEM immediately upon generation. Ensure the SIEM utilizes an append-only architecture so attackers cannot modify stored logs.